

# SEGURIDAD PRÁCTICA DE IA EN AZURE

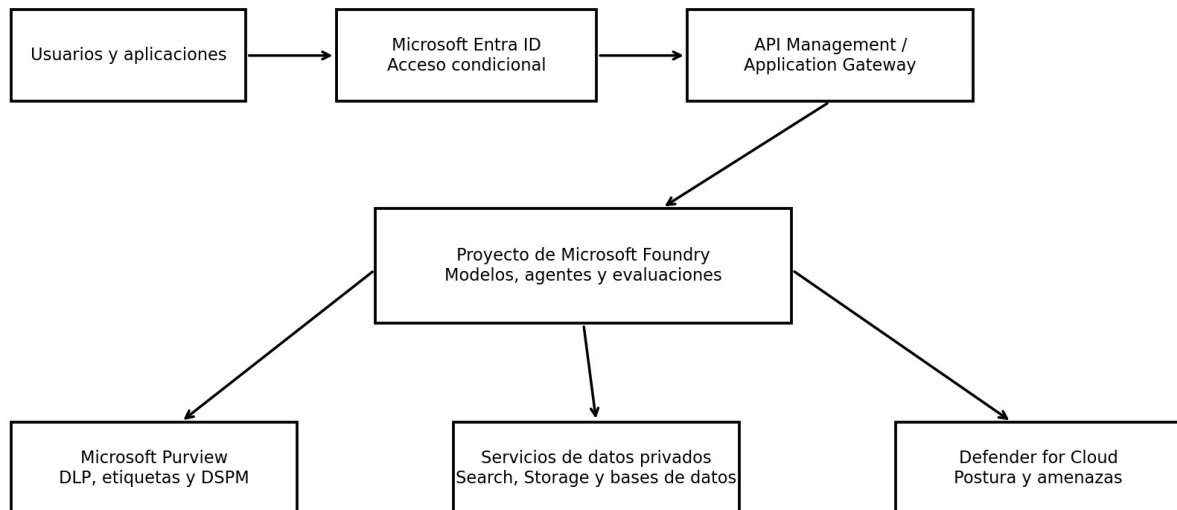
*Cómo proteger Microsoft Foundry, Copilot, Purview, Entra ID, RAG, agentes y MCP*

Manual práctico y accesible para ingenieros de seguridad, arquitectos, profesionales de GRC, desarrolladores y líderes de tecnología

**Alberto (Al) Leiva**

Versión 1.0 • Julio de 2026

## Arquitectura de referencia con defensa en profundidad



Use conectividad privada, identidades administradas, privilegio mínimo, protección de datos y monitoreo continuo.

*Licencia: CC BY-NC-SA 4.0*

## Propósito y aviso de uso responsable

Este manual explica cómo diseñar, desplegar, gobernar y monitorear cargas de trabajo de inteligencia artificial en Microsoft Azure mediante una estrategia de defensa en profundidad. Está destinado exclusivamente a usos autorizados, éticos y legales. Los nombres de productos y las interfaces cambian con el tiempo; verifique los detalles de implementación en la documentación vigente de Microsoft antes de utilizarlos en producción.

***La seguridad humana es lo primero.*** Ninguna prueba de seguridad, fecha de entrega, objetivo empresarial o experimento técnico es más importante que la seguridad, la dignidad, la privacidad y los derechos de las personas afectadas por un sistema de IA.

## Cómo utilizar este manual

- Lea primero los capítulos 1 al 4 si está comenzando con la seguridad de IA en Azure.
- Utilice los capítulos 5 al 13 como guías de implementación.
- Utilice los capítulos 14 al 16 para pruebas, operaciones, respuesta a incidentes y gobierno.
- Use las listas de verificación y los ejemplos como evidencia de portafolio o plantillas internas.
- Adapte cada control a los datos, amenazas, obligaciones legales y tolerancia al riesgo de su organización.

## Tabla de contenido

- 1. Fundamentos de seguridad de IA en Azure
- 2. Responsabilidad compartida y modelado de amenazas
- 3. Arquitectura segura de referencia
- 4. Identidad y acceso con Microsoft Entra ID
- 5. Aislamiento de red y conectividad privada
- 6. Protección de datos con Microsoft Purview
- 7. Seguridad de proyectos en Microsoft Foundry
- 8. Protección de modelos, instrucciones y contenido
- 9. Sistemas RAG seguros
- 10. Agentes de IA e identidades no humanas
- 11. Seguridad de servidores y herramientas MCP
- 12. Seguridad y gobierno de Copilot
- 13. Defender for Cloud y administración continua de la postura
- 14. Pruebas, evaluación y red teaming
- 15. Registros, monitoreo y respuesta a incidentes
- 16. Gobierno, cumplimiento y evidencia de auditoría
- 17. Hoja de ruta práctica
- 18. Listas de verificación y artefactos de ejemplo
- 19. Glosario
- 20. Referencias oficiales



# 1. Fundamentos de seguridad de IA en Azure

Una solución de IA en Azure es mucho más que un punto de conexión a un modelo. Normalmente incluye identidades, aplicaciones, redes, instrucciones, fuentes de datos, índices de búsqueda, almacenamiento, API, agentes, herramientas, monitoreo y decisiones humanas. Un diseño seguro protege todo el sistema.

## Objetivos principales

| Objetivo             | Aplicación a la IA                                                                                                          |
|----------------------|-----------------------------------------------------------------------------------------------------------------------------|
| Confidencialidad     | Evitar la divulgación no autorizada de instrucciones, archivos, embeddings, secretos, resultados y datos de fundamentación. |
| Integridad           | Evitar cambios no autorizados en modelos, instrucciones del sistema, índices, herramientas, evaluaciones y configuraciones. |
| Disponibilidad       | Mantener servicios confiables y controlar abuso, denegación de servicio y aumentos inesperados de costos.                   |
| Privacidad           | Limitar la recopilación, uso, conservación y exposición de datos personales.                                                |
| Seguridad humana     | Reducir conductas dañinas, discriminatorias, engañosas o inseguras y ofrecer supervisión adecuada.                          |
| Rendición de cuentas | Registrar quién aprobó, modificó, utilizó y supervisó el sistema.                                                           |

## Ocho principios prácticos

1. Conozca cada activo de IA y su propietario.
2. Use Microsoft Entra ID e identidades administradas en lugar de secretos permanentes cuando sea posible.
3. Otorgue únicamente los permisos necesarios y en el alcance más reducido.
4. Use conectividad privada y controle las salidas de red en cargas sensibles.
5. Clasifique y proteja los datos antes de conectarlos a la IA.
6. Trate las instrucciones, el contenido recuperado, las herramientas y las salidas como datos no confiables.
7. Pruebe la seguridad antes de publicar y después de cambios importantes.
8. Monitoree continuamente y conserve evidencia.

# 2. Responsabilidad compartida y modelado de amenazas

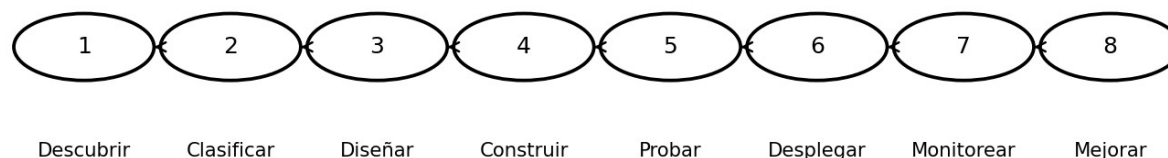
Microsoft protege la plataforma de nube y proporciona capacidades de seguridad. El cliente sigue siendo responsable de la configuración, las identidades, las aplicaciones, los datos, las instrucciones, los permisos de herramientas, el monitoreo, el gobierno y las decisiones tomadas con resultados de IA.

| Capa                    | Responsabilidades habituales del cliente                                                              |
|-------------------------|-------------------------------------------------------------------------------------------------------|
| Inquilino y suscripción | Grupos de administración, políticas, presupuestos, roles, registros y organización de recursos.       |
| Identidad               | Ciclo de vida de usuarios, acceso privilegiado, identidades de carga de trabajo y credenciales.       |
| Red                     | Puntos de conexión privados, DNS, firewalls, egreso, segmentación y exposición de API.                |
| Datos                   | Clasificación, permisos, retención, cifrado, DLP y minimización.                                      |
| Aplicación              | Validación, autorización, sesiones, dependencias y programación segura.                               |
| Comportamiento de IA    | Instrucciones del sistema, fundamentación, controles de contenido, evaluaciones y supervisión humana. |
| Operaciones             | Monitoreo, alertas, incidentes, cambios y evidencia.                                                  |

### Preguntas de modelado de amenazas

- ¿Quién puede enviar instrucciones, cargar archivos, cambiar configuraciones, desplegar modelos o invocar herramientas?
- ¿Qué información sensible puede entrar en instrucciones, índices, registros, resultados o conjuntos de evaluación?
- ¿Qué ocurre si el contenido recuperado contiene instrucciones ocultas o maliciosas?
- ¿Puede el modelo modificar registros, enviar mensajes, ejecutar código o aprobar transacciones?
- ¿Qué fallas podrían afectar a personas, infringir la ley o revelar datos?
- ¿Cómo se revisan, cuestionan, corrigen y apelan los resultados de alto impacto?
- ¿Cuál es el radio máximo de impacto de una identidad, agente, índice o secreto comprometido?

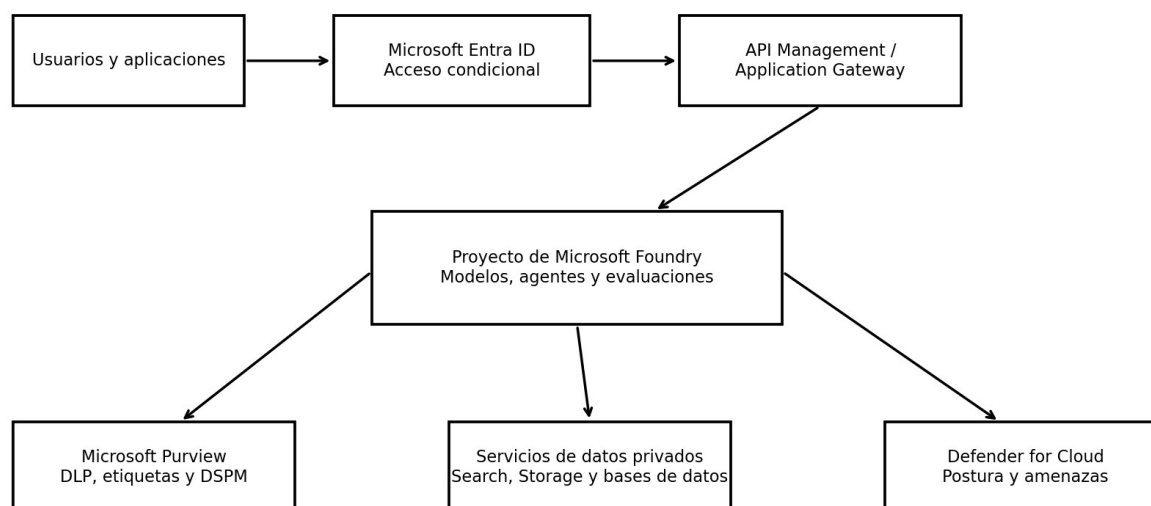
## Ciclo de vida seguro de la inteligencia artificial



La seguridad, la privacidad, el cumplimiento y la supervisión humana continúan durante todas las etapas.

### 3. Arquitectura segura de referencia

#### Arquitectura de referencia con defensa en profundidad



Use conectividad privada, identidades administradas, privilegio mínimo, protección de datos y monitoreo continuo.

Una base sólida utiliza Microsoft Entra ID, Azure RBAC con privilegio mínimo, identidades administradas, puntos de conexión privados, egreso controlado, fuentes de datos protegidas, controles de contenido, Microsoft Purview, Microsoft Defender for Cloud y monitoreo centralizado.

#### Límites de confianza recomendados

- Usuarios y dispositivos

- Aplicación y API
- Proyecto de Foundry y punto de conexión del modelo
- Recuperación y datos empresariales
- Herramientas del agente y servicios externos
- Administración y despliegue
- Monitoreo, auditoría y respuesta a incidentes

## 4. Identidad y acceso con Microsoft Entra ID

La identidad es el principal plano de control. Separe administradores humanos, desarrolladores, aplicaciones, canalizaciones y agentes. No permita que una sola entidad de servicio o una clave compartida represente a todo un entorno.

### Identidades humanas

- Exija autenticación multifactor.
- Use Acceso condicional según dispositivo, ubicación, riesgo y sensibilidad.
- Use Privileged Identity Management para acceso administrativo temporal.
- Separe las cuentas administrativas de producción de las cuentas de uso diario.
- Revise el acceso periódicamente y elimine asignaciones sin uso.
- Use flujos de aprobación para acceso temporal.

### Identidades de carga de trabajo

Utilice identidades administradas para aplicaciones alojadas en Azure cuando el servicio de destino admita autenticación de Microsoft Entra. Use federación de identidad de carga de trabajo en escenarios de CI/CD compatibles para evitar secretos almacenados.

| Tipo                                           | Uso recomendado                                          | Nota de seguridad                                    |
|------------------------------------------------|----------------------------------------------------------|------------------------------------------------------|
| Identidad administrada asignada por el sistema | Un recurso de Azure con el mismo ciclo de vida           | Se elimina con el recurso y simplifica la propiedad. |
| Identidad administrada asignada por el usuario | Varios recursos o identidad estable                      | Revise cuidadosamente la reutilización.              |
| Federación de identidad                        | GitHub Actions, Kubernetes y cargas externas compatibles | Evita secretos permanentes.                          |
| Entidad de servicio con certificado            | Escenarios heredados o no compatibles                    | Prefiera certificados y rote periódicamente.         |
| Clave de API                                   | Solo cuando Entra no esté disponible                     | Guárdela en Key Vault, restrinja, rote y monitoree.  |

## 5. Aislamiento de red y conectividad privada

Los controles de red reducen la exposición, pero no sustituyen los controles de identidad. Para cargas sensibles, use puntos de conexión privados, DNS privado, redes virtuales administradas cuando estén disponibles y controles explícitos de salida.

9. Deshabilite el acceso público cuando los requisitos lo permitan.
10. Cree puntos de conexión privados para Foundry, Storage, Search, Key Vault y bases de datos.
11. Configure zonas DNS privadas y valide la resolución.
12. Dirija el egreso por un firewall o mecanismo aprobado.
13. Permita únicamente destinos necesarios y documente cada excepción.
14. Proteja el acceso administrativo.
15. Pruebe el comportamiento de bloqueo seguro cuando falle DNS, firewall o Private Link.

**Falla común:** El proyecto protege el modelo con un punto privado, pero deja públicamente accesibles el almacenamiento, la búsqueda o las herramientas.

## 6. Protección de datos con Microsoft Purview

Microsoft Purview puede ayudar a descubrir datos sensibles, aplicar protección de información, ejecutar DLP, investigar actividades de riesgo y proporcionar visibilidad sobre la postura de datos de aplicaciones y agentes de IA.

16. Inventarie las fuentes utilizadas para instrucciones, fundamentación, ajuste, evaluación y registros.
17. Clasifique los datos e identifique obligaciones legales, contractuales, de residencia y retención.
18. Aplique etiquetas de confidencialidad y controles de acceso.
19. Configure políticas DLP para interacciones aprobadas.
20. Use las capacidades actuales de DSPM para identificar uso riesgoso y datos sin protección.
21. Revise señales de riesgo interno y auditoría cuando sea legal y apropiado.
22. Pruebe las políticas con datos realistas.
23. Registre excepciones, propietarios, fechas de vencimiento y controles compensatorios.

| Ubicación                 | Riesgos principales                                 | Controles mínimos                                     |
|---------------------------|-----------------------------------------------------|-------------------------------------------------------|
| Instrucciones e historial | Datos personales, secretos y datos confidenciales   | Minimización, DLP, retención y acceso restringido.    |
| Archivos cargados         | Malware, exceso de permisos e instrucciones ocultas | Análisis, clasificación, autorización y cuarentena.   |
| Índice vectorial          | Contenido sensible y filtración entre usuarios      | Permisos de origen, separación, cifrado y filtrado.   |
| Conjuntos de evaluación   | Copia de datos productivos a entornos inferiores    | Desidentificación, restricción, versión y aprobación. |
| Resultados                | Reconstrucción sensible, consejos dañinos o falsos  | Fundamentación, DLP, supervisión y procedencia.       |
| Registros                 | Conservación excesiva de instrucciones o datos      | Redacción, acceso limitado y retención definida.      |

## 7. Seguridad de proyectos en Microsoft Foundry

Trate cada proyecto de Foundry como un límite de seguridad con propietario, clasificación, entorno, propósito y proceso de despliegue controlado.

- Separe desarrollo, pruebas y producción.
- Use infraestructura como código y revisión por pares.
- Use autenticación de Entra e identidades administradas.
- Restrinja quién puede desplegar modelos, conectar datos, modificar conexiones o publicar agentes.
- Use claves administradas por el cliente cuando la política lo exija y el servicio lo admita.
- Active la configuración de diagnóstico.
- Aplique Azure Policy y recomendaciones de Defender.
- Use etiquetas de propietario, entorno, clasificación, servicio y fecha de revisión.
- Configure cuotas, límites y presupuestos.

### Seguridad de conexiones

Las conexiones a Search, Storage, bases de datos, API y herramientas son rutas frecuentes de ataque. Prefiera acceso basado en identidad. Si un secreto es inevitable, guárdelo en Key Vault, restrinja su recuperación, rótelos y evite que aparezca en instrucciones, código, notebooks o registros.

## 8. Protección de modelos, instrucciones y contenido

### Defensa contra inyección de instrucciones

La inyección de instrucciones ocurre cuando una entrada no confiable intenta anular las reglas del sistema, revelar datos o abusar de herramientas. Ningún filtro único resuelve el problema.

- Separe claramente instrucciones del sistema, entrada del usuario, contenido recuperado y resultados de herramientas.
- Trate documentos y contenido web como datos, no como instrucciones confiables.
- Use herramientas con privilegio mínimo y aplique autorización fuera del modelo.
- Limite acciones mediante esquemas estructurados y validación determinista.
- Use Azure AI Content Safety y protecciones contra ataques de instrucciones cuando corresponda.
- No coloque secretos ni credenciales amplias en el contexto.
- Exija confirmación o aprobación humana para acciones de alto impacto.
- Evalúe jailbreaks, inyección indirecta y exfiltración.

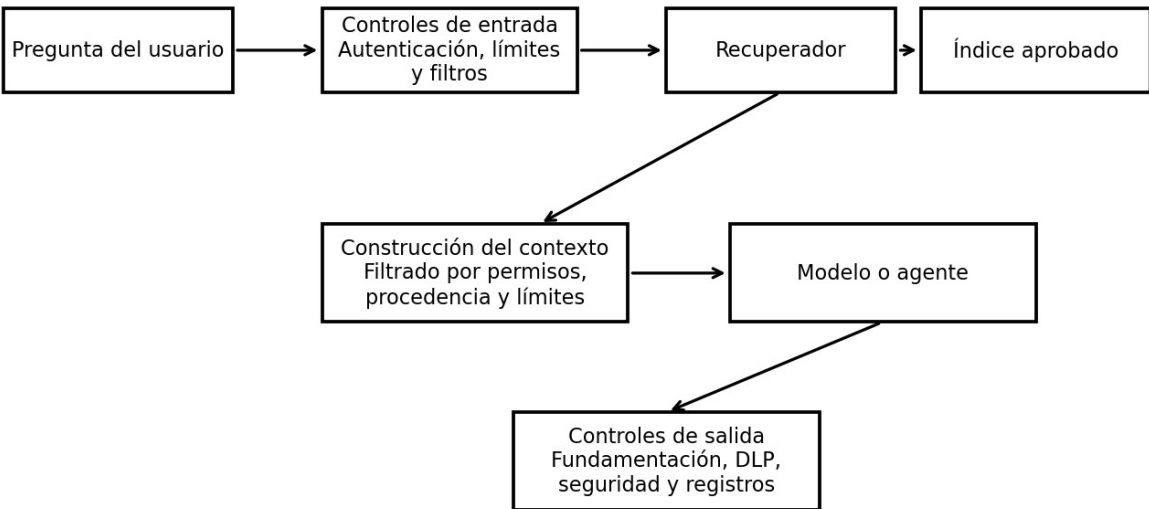
### Seguridad de las salidas

- Revise resultados para detectar contenido dañino y datos sensibles.
- Exija citas o referencias para respuestas basadas en conocimiento.
- Comunique incertidumbre y no presente resultados probabilísticos como hechos verificados.

- Aplique reglas específicas en contextos médicos, legales, financieros, laborales o de seguridad.
- Ofrezca una respuesta segura cuando no exista evidencia suficiente.
- Registre decisiones de política sin almacenar contenido sensible innecesario.

## 9. Sistemas RAG seguros

### Flujo seguro de generación aumentada por recuperación (RAG)



RAG no vuelve automáticamente preciso o seguro a un modelo. Agrega canalizaciones, índices, permisos, analizadores y lógica de recuperación que también deben protegerse.

- Autorice en el momento de la consulta.
- Conserve los permisos de las fuentes y aplique filtrado de seguridad.
- Separe inquilinos, departamentos o clasificaciones cuando un índice compartido genere riesgo.
- Valide tipos de archivo y analice el contenido cargado.
- Registre procedencia, propietario, clasificación y fecha.
- Defiéndase contra documentos contaminados e inyección indirecta.
- Limite la cantidad y el tamaño de fragmentos.
- Exija que el modelo distinga texto fuente de instrucciones.
- Devuelva citas y permita inspeccionar la fuente.
- Monitoree patrones anómalos y enumeración del índice.

| Prueba                                              | Resultado esperado                                     |
|-----------------------------------------------------|--------------------------------------------------------|
| El usuario solicita documentos de otro departamento | No se recupera ni infiere contenido no autorizado.     |
| Un documento contiene 'ignore todas las reglas'     | El texto se trata como dato y no modifica la política. |
| Se elimina una fuente o se revoca el acceso         | El índice se actualiza y se elimina el acceso.         |

|                                          |                                                                |
|------------------------------------------|----------------------------------------------------------------|
| Se solicitan secretos o datos personales | La solicitud se bloquea o se procesa según política.           |
| Las citas no respaldan la respuesta      | El sistema expresa incertidumbre o evita afirmar verificación. |

## 10. Agentes de IA e identidades no humanas

Los agentes pueden planificar, recuperar información, llamar herramientas y ejecutar acciones. Su riesgo depende menos de la conversación y más de lo que pueden leer, modificar o activar.

- Proporcione a cada agente de producción una identidad única cuando sea posible.
- Asigne permisos para su propósito exacto.
- Separe herramientas de lectura y escritura.
- Use aprobaciones para acciones destructivas, financieras, legales, laborales o de seguridad.
- Registre usuario iniciador, identidad del agente, llamada, parámetros, resultado y aprobación.
- Impida que el agente amplíe sus propios permisos.
- Retire agentes sin uso y revise su propiedad.

**Regla esencial:** *El modelo propone; la lógica confiable autoriza. Nunca dependa de que el propio modelo declare que una acción está permitida.*

## 11. Seguridad de servidores y herramientas MCP

Model Context Protocol (MCP) permite que aplicaciones de IA descubran y utilicen herramientas o recursos contextuales de forma estandarizada. Puede mejorar la integración, pero también crea un puente poderoso desde el lenguaje natural hacia sistemas sensibles.

- Mantenga un inventario aprobado de servidores MCP, propietarios, versiones y clasificaciones.
- Use transporte autenticado y cifrado.
- Aplique autorización por servidor o herramienta.
- Valide esquemas y rechace parámetros inesperados.
- Permita únicamente herramientas y destinos aprobados.
- Ejecute con permisos mínimos de sistema operativo, red y nube.
- Separe desarrollo y producción.
- Fije y revise dependencias.
- Registre cada llamada y correlaciónela con usuario y agente.
- Exija aprobación humana para acciones de alto impacto.
- Devuelva solo los datos mínimos necesarios.
- Pruebe intentos de invocar herramientas ocultas o no autorizadas.

| Escenario                                                   | Control                                                                         |
|-------------------------------------------------------------|---------------------------------------------------------------------------------|
| Documento malicioso solicita una herramienta administrativa | Jerarquía de instrucciones, lista permitida, autorización externa y aprobación. |

|                                                         |                                                                                    |
|---------------------------------------------------------|------------------------------------------------------------------------------------|
| Servidor MCP comprometido devuelve contexto contaminado | Autenticación, integridad, procedencia y validación.                               |
| Herramienta devuelve demasiados registros               | Autorización del servidor, límites, filtrado de campos y DLP.                      |
| El agente intenta inyección de comandos                 | Argumentos estructurados, validación estricta y sin construcción directa de shell. |
| Credencial MCP robada                                   | Identidad de corta duración, autenticación sin secretos, monitoreo y revocación.   |

## 12. Seguridad y gobierno de Copilot

La seguridad de Copilot comienza con identidad, permisos de datos, protección de información y gobierno. Un Copilot puede mostrar información a la que un usuario ya tiene acceso, por lo que debe corregirse el exceso de permisos antes de una adopción amplia.

- Evalúe datos compartidos en exceso y permisos obsoletos.
- Aplique etiquetas y DLP.
- Defina usos aprobados y prohibidos.
- Controle complementos, conectores, agentes y acciones externas.
- Revise señales de auditoría y riesgo.
- Capacite a los usuarios para no introducir secretos o datos regulados en herramientas no aprobadas.
- Ofrezca un canal para reportar resultados inseguros, incorrectos o sensibles.
- Mida adopción y riesgo conjuntamente.

## 13. Defender for Cloud y postura continua

Microsoft Defender for Cloud puede proporcionar descubrimiento de cargas de IA, recomendaciones de postura, contexto de rutas de ataque y protección frente a amenazas para servicios compatibles. Debe formar parte de un modelo operativo más amplio.

24. Active los planes apropiados en las suscripciones que alojan IA.
25. Revise el panel de seguridad de datos e IA y el inventario de cargas.
26. Priorice exposición pública, privilegios excesivos, datos sensibles y rutas explotables.
27. Asigne recomendaciones a propietarios con fechas objetivo.
28. Integre alertas con Defender XDR o el SIEM.
29. Valide cobertura después de despliegues o cambios de red.
30. Registre excepciones y verifique controles compensatorios.

## 14. Pruebas, evaluación y red teaming

Las pruebas deben cubrir aplicación, identidad, datos, red, comportamiento del modelo, recuperación, agentes, herramientas y operaciones. Realice pruebas únicamente con autorización y dentro de un alcance definido.

| Categoría                | Ejemplos                                                                    |
|--------------------------|-----------------------------------------------------------------------------|
| Control de acceso        | Filtración entre usuarios, escalamiento y falta de autorización por objeto. |
| Ataques de instrucciones | Inyección directa e indirecta, jailbreaks y revelación de reglas.           |
| Protección de datos      | Instrucciones sensibles, exposición, enumeración y registros.               |
| Integridad de RAG        | Documentos contaminados, permisos obsoletos y citas sin respaldo.           |
| Seguridad de agentes     | Herramientas no autorizadas, parámetros manipulados y autonomía excesiva.   |
| Seguridad de aplicación  | Problemas web/API, dependencias e inseguridad de serialización.             |
| Abuso y disponibilidad   | Evasión de límites, agotamiento y amplificación de costos.                  |
| Factores humanos         | Confianza engañosa, advertencias insuficientes y falta de accesibilidad.    |

### Evidencia de evaluación

- Caso de prueba y propósito
- Comportamiento seguro esperado
- Resultado real
- Severidad y usuarios afectados
- Versiones del modelo, instrucciones, índice, herramienta y aplicación
- Revisor y fecha
- Propietario de corrección y plazo
- Resultado de la nueva prueba y aprobación

## 15. Registros, monitoreo y respuesta a incidentes

### Qué registrar

- Autenticación y autorización
- Cambios administrativos y despliegues
- Metadatos de invocación
- Llamadas a herramientas y resultados
- Bloqueos de políticas
- Fuentes recuperadas y decisiones de autorización

- Límites y cuotas
- Alertas de Defender, Purview, Key Vault, red y aplicación
- Aprobaciones humanas

**Advertencia de privacidad:** No almacene automáticamente instrucciones, fragmentos recuperados y resultados completos. Defina una finalidad, redacte datos sensibles, restrinja acceso y aplique retención.

## Guía de respuesta a incidentes de IA

31. Identificar y clasificar el evento.
32. Contener el acceso: desactivar agente, punto de conexión, herramienta, identidad o conexión.
33. Conservar registros y configuraciones.
34. Evaluar exposición, acciones dañinas y personas afectadas.
35. Revocar credenciales y corregir permisos.
36. Eliminar contenido contaminado y reconstruir índices si es necesario.
37. Corregir lógica, instrucciones o controles.
38. Notificar a las partes obligatorias.
39. Volver a probar antes de restaurar.
40. Documentar lecciones y actualizar controles.

## 16. Gobierno, cumplimiento y evidencia de auditoría

Un programa seguro necesita propiedad responsable, casos de uso aprobados, clasificación de riesgo, controles del ciclo de vida y evidencia. Puede mapearse a NIST AI RMF, ISO/IEC 42001, ISO/IEC 27001, Microsoft Cloud Security Benchmark y obligaciones legales aplicables.

- Inventario de sistemas de IA
- Propietario empresarial y técnico
- Propósito y usos prohibidos
- Diagrama de arquitectura y flujo de datos
- Clasificación y evaluación de privacidad
- Modelo de amenazas y evaluación de riesgo
- Documentación del modelo y proveedor
- Plan de controles
- Resultados de pruebas
- Diseño de supervisión humana
- Plan de monitoreo e incidentes
- Registro de cambios y aprobaciones
- Plan de retiro y eliminación de datos

**Ejemplo de riesgo:** Un asistente RAG de atención al cliente podría revelar notas restringidas porque los permisos de origen no se aplican de manera uniforme. Tratamiento: filtrado en tiempo de consulta, separación de colecciones, validación de revocación, DLP y pruebas entre usuarios.

## 17. Hoja de ruta práctica

### Primeros 30 días: descubrir y estabilizar

- Inventariar recursos, modelos, agentes, Copilots, datos y propietarios.
- Identificar exposición pública, claves compartidas, privilegios excesivos y cargas sin monitoreo.
- Activar registros, presupuestos y visibilidad básica.
- Bloquear usos claramente prohibidos y eliminar recursos abandonados.
- Crear un estándar mínimo y un proceso de excepciones.

### Días 31 a 60: fortalecer y probar

- Migrar a identidades administradas y reducir el alcance de RBAC.
- Implementar conectividad privada.
- Clasificar datos y configurar DLP prioritario.
- Modelar amenazas en RAG, agentes y MCP.
- Ejecutar evaluaciones y corregir hallazgos de alto riesgo.

### Días 61 a 90: operar de manera sostenible

- Automatizar políticas, infraestructura y evidencia.
- Integrar alertas con respuesta a incidentes.
- Establecer revisiones periódicas de acceso, agentes, índices y proveedores.
- Crear métricas ejecutivas.
- Capacitar a desarrolladores, seguridad, propietarios de datos y usuarios.

## 18. Listas de verificación y artefactos de ejemplo

### Lista de preparación para producción

- ☐ Propietarios empresarial y técnico identificados
- ☐ Propósito aprobado y usos prohibidos
- ☐ Clasificación de datos completada
- ☐ Modelo de amenazas revisado
- ☐ Autenticación de Entra habilitada
- ☐ Identidades administradas utilizadas
- ☐ RBAC de privilegio mínimo verificado
- ☐ Exposición pública justificada o deshabilitada
- ☐ Puntos privados y DNS probados
- ☐ Secretos inevitables almacenados en Key Vault

- ☐ Controles de Purview y retención definidos
- ☐ Filtrado de seguridad RAG probado
- ☐ Herramientas de agentes y MCP aprobadas
- ☐ Aprobación para acciones de alto impacto
- ☐ Controles de contenido e instrucciones probados
- ☐ Defender y monitoreo habilitados
- ☐ Guía de incidentes ejercitada
- ☐ Procedimientos de reversión y apagado probados
- ☐ Accesibilidad y supervisión humana revisadas
- ☐ Aprobación final registrada

### Campos de inventario de ejemplo

| Campo                  | Ejemplo                                            |
|------------------------|----------------------------------------------------|
| Nombre                 | Asistente de conocimiento para atención al cliente |
| Propietario            | Operaciones de atención al cliente                 |
| Entorno                | Producción                                         |
| Suscripción y grupo    | AI-Prod / rg-support-ai                            |
| Proyecto Foundry       | support-assistant-prod                             |
| Modelos                | Nombre y versión aprobados                         |
| Fuentes de datos       | Base de conocimiento y catálogo aprobados          |
| Agentes y herramientas | Búsqueda, consulta de caso y borrador de respuesta |
| Clasificación          | Confidencial; datos personales limitados           |
| Usuarios               | Personal autorizado                                |
| Nivel de riesgo        | Alto                                               |
| Fecha de revisión      | Trimestral o después de un cambio importante       |

## 19. Glosario

| Término    | Definición                                                                                 |
|------------|--------------------------------------------------------------------------------------------|
| Agente     | Componente de IA que puede recuperar información, llamar herramientas y ejecutar acciones. |
| Azure RBAC | Control de acceso basado en roles de Azure.                                                |
| DSPM       | Administración de la postura de seguridad de datos.                                        |
| Embedding  | Representación numérica de contenido usada                                                 |

|                               |                                                                                                     |
|-------------------------------|-----------------------------------------------------------------------------------------------------|
|                               | para búsquedas de similitud.                                                                        |
| Foundry                       | Plataforma de Microsoft Azure para crear, evaluar, desplegar y operar aplicaciones y agentes de IA. |
| Fundamentación                | Proporcionar contexto aprobado para mejorar relevancia y reducir afirmaciones sin respaldo.         |
| Identidad administrada        | Identidad de carga de trabajo administrada por Azure.                                               |
| MCP                           | Model Context Protocol.                                                                             |
| Inyección de instrucciones    | Entrada que intenta anular reglas, revelar datos o abusar de herramientas.                          |
| RAG                           | Generación aumentada por recuperación.                                                              |
| Filtrado de seguridad         | Filtrado del contenido recuperado según la autorización del usuario.                                |
| Identidad de carga de trabajo | Identidad no humana de una aplicación, servicio, agente o automatización.                           |

## 20. Referencias oficiales

[Mejores prácticas de seguridad de IA en Azure](#)

[Línea base de seguridad de Microsoft Foundry](#)

[Aislamiento de red de Microsoft Foundry](#)

[Autenticación y autorización en Microsoft Foundry](#)

[RBAC para Microsoft Foundry](#)

[Identidades administradas de Azure](#)

[Microsoft Entra Workload ID](#)

[Protecciones de Microsoft Purview para IA](#)

[DSPM para IA](#)

[Microsoft Purview para agentes de IA](#)

[Postura de seguridad de IA en Defender for Cloud](#)

[Protección contra amenazas de IA](#)

[Azure AI Content Safety](#)

[Microsoft Foundry Agent Service](#)

***Nota de mantenimiento:*** Los servicios y nombres de productos de Microsoft evolucionan. Revise las referencias oficiales antes de implementar controles o publicar nuevas ediciones.

## Licencia y atribución

Copyright © 2026 Alberto (Al) Leiva. Este manual se distribuye bajo la licencia Creative Commons Atribución-NoComercial-CompartirIgual 4.0 Internacional (CC BY-NC-SA 4.0).